

EU GDPR ARTICLE 28 - PROCESSOR OBLIGATIONS (REGULATORY REFERENCE)

Under GDPR Article 28, a controller may only use a processor that provides sufficient guarantees to implement appropriate technical and organisational measures. Processing by a processor must be governed by a binding written contract - a Data Processing Agreement (DPA).

Mandatory DPA terms include: subject matter and duration of processing; nature and purpose of processing; type of personal data and categories of data subjects; processing only on documented instructions of the controller; confidentiality commitments; security measures per Article 32; sub-processor authorisation; assistance with data-subject rights; breach notification; deletion or return of data; and audit rights.

A Data Processing Agreement (DPA) MUST be executed BEFORE any EU personal data is shared with the processor. Failure to comply with Article 28 can result in administrative fines of up to EUR 20 million or 4% of total worldwide annual turnover, whichever is higher.